

Customer Discovery Summary Report

Synthesis of 100 structured interviews with red teamers, penetration testers, and offensive security professionals.

100

Interviews

7

Persona Types

5

Questions

June 2026

Date

CONTENTS

1. Respondent Profile
2. Key Themes
3. Workflow & Pain Points
4. Attitudes Toward Automation and AI
5. Trust Requirements
6. Pricing Sensitivity
7. Feature Priority Ranking
8. Segment-Specific Findings
9. Notable Quotes
10. Recommendations for Chelys

1. RESPONDENT PROFILE

One hundred cybersecurity professionals were interviewed over a two-week period. Respondents were sourced through LinkedIn outreach, conference contacts, and community referrals. The sample skews toward practitioners with direct hands-on testing responsibilities rather than management or advisory roles, reflecting Chelys's primary buyer persona.

Segment	Count	% of Sample
Red Team Operators and Leads	35	35%
Penetration Testers (External/Web/Network)	28	28%
Bug Bounty Hunters / Independent Researchers	15	15%
Freelance / Independent Consultants	12	12%
Corporate / Enterprise Red Team	10	10%

Geographic distribution: 52% United States and Canada, 28% Europe, 10% Asia-Pacific, 6% Latin America, 4% Africa and Middle East. Experience levels ranged from 18 months (junior tester) to 20 years (senior independent). The median respondent had 6 years of offensive security experience.

2. KEY THEMES

Mechanical work is the universal pain point

Across all segments and experience levels, respondents expressed frustration with the mechanical, repetitive phases of engagements -- subdomain enumeration, port scanning, service fingerprinting, Nuclei runs, report template population. Senior practitioners are particularly frustrated because these tasks feel beneath their expertise but still consume significant time.

Report writing is as painful as the mechanical testing

Ninety-one of 100 respondents cited report writing -- not the testing itself -- as a major time sink. Specifically: triage of scanner output, CVSS calibration, compliance framework mapping, and writing executive-friendly business impact narratives. Several described spending more time on the report than the engagement itself.

Trust in AI requires transparency and control

Skepticism about autonomous systems was not primarily technical -- respondents did not doubt that an AI could run tools. The core concern was whether they could understand and control what the system was doing. 'Show me what it is doing and let me stop it instantly' was the most common formulation of the trust requirement.

Scope enforcement is a non-negotiable hard requirement

Without exception, respondents identified scope violation as the critical failure mode they feared. An AI that tests something outside the agreed scope creates immediate legal and professional liability. This requirement was stated more strongly than any feature request.

Compliance mapping would unlock regulated markets

Healthcare, financial services, and government-adjacent respondents identified compliance framework mapping as a potentially decisive differentiator. The ability to produce findings already mapped to HIPAA, PCI DSS, NIST, DORA, or SAMA controls was valued in some cases above the technical testing capability itself.

Pricing models need to match workflow patterns

Monthly subscriptions were the dominant preference (67%), with per-scan pricing favored by bug bounty hunters and light users (21%). Enterprise respondents expected annual licensing. A pause or flexible suspension option was mentioned by 34 respondents as important for handling gaps between engagements.

3. WORKFLOW AND PAIN POINTS

Respondents were asked to walk through their typical engagement workflow. The following phases and their associated pain points were most frequently cited:

Phase	% Citing as Pain Point	Primary Friction
Report writing / documentation	91%	Time, consistency, framework mapping
Initial recon and asset discovery	74%	Repetitive, mechanical, slow
Vulnerability triage	68%	False positives, severity calibration
Compliance mapping	52%	Manual, error-prone, framework-specific
Scope management	44%	Changing scope, client communication gaps
Post-exploitation documentation	38%	Evidence capture while in flow state
Credential attack timing	31%	Lockout risk, slow by necessity
Client communication mid-engagement	29%	Context switching, flow disruption

Tool Usage Across Respondents

The following tools were mentioned most frequently as part of respondents' standard workflows:

Burp Suite		89%	Universal f
Nmap		85%	Universal f
Nuclei		79%	Dominant t
BloodHound / SharpHound		68%	Standard f
Metasploit		61%	Exploit del
Impacket / CrackMapExec		54%	AD creden
Cobalt Strike / Sliver		41%	C2 framew
ScoutSuite / Prowler		38%	Cloud sec
FFUF / Gobuster		36%	Directory a
Subfinder / Amass		71%	Subdomai

4. ATTITUDES TOWARD AUTOMATION AND AI

Respondents were asked about their experience with existing automated and AI-based security tools. Attitudes clustered into four categories:

Attitude	% of Sample	Characteristic Concern
Skeptical but open	38%	Have been burned by overpromising tools before
Pragmatic adopter	31%	Use what works, evaluate on results not hype
Enthusiastic early adopter	18%	Want to extend and integrate the platform
Resistant	13%	Concerned about OPSEC, liability, or accuracy

The 'resistant' segment was not categorically opposed to AI tools -- their resistance was specifically to tools that are noisy, inaccurate, or create liability. None of the 100 respondents said they would never use an AI tool under any circumstances.

The most common criticism of existing AI pentest platforms (mentioned by 61 respondents who had tried one) was inaccurate severity calibration -- tools producing critical findings for low-impact issues and missing genuinely exploitable vulnerabilities. The second most common criticism was false positives requiring as much triage time as manual testing.

5. TRUST REQUIREMENTS

When asked what they would need to see before trusting an autonomous pentest platform to take actions on engagements, respondents identified the following requirements in order of frequency:

Requirement	Respondents Citing This
-------------	-------------------------

Single-click kill switch that is guaranteed to stop all activity	82 respondents
Strict, verifiable scope enforcement with hard boundaries	97 respondents
Human approval required for exploit actions	71 respondents
Full action log exportable for client documentation	68 respondents
Trial on a lab or test environment they control before production use	91 respondents
Accurate findings (validation on known-vulnerable environments)	84 respondents
Clear answer on who is liable if something goes wrong	59 respondents

The single most-cited requirement -- scope enforcement (97 respondents) -- was framed as a hard requirement by every segment. The phrasing varied: 'it cannot touch anything outside the defined targets,' 'scope violation is an immediate dealbreaker,' 'the moment it goes out of scope I am personally liable.' This is not a feature -- it is a table-stakes requirement.

6. PRICING SENSITIVITY

Respondents were asked what fair pricing would look like. Responses varied significantly by segment, workflow type, and use case:

Segment	Preferred Model	Price Range
Enterprise corporate red team	Annual license	\$100K - \$400K/year
Consulting team (3-6 people)	Per-seat monthly	\$500 - \$900/seat/month
Senior solo consultant	Monthly subscription	\$600 - \$1,000/month
Mid-level solo consultant	Monthly subscription	\$400 - \$700/month
Junior / early career	Monthly subscription	\$200 - \$400/month
Bug bounty (full-time)	Per-scan or low monthly	\$200 - \$350/month or \$25-60/scan
Bug bounty (part-time)	Per-scan	\$100 - \$200/month or \$15-30/scan
Regulated sector (healthcare/finance)	Annual with compliance tier	20-40% premium over base

Monthly subscription was the dominant preference (67%), driven by the lumpy, project-based nature of consulting work. The ability to pause or suspend a subscription during gaps between projects was mentioned by 34 respondents as important. Annual contracts were only acceptable to respondents with predictable volume -- corporate red teams and established consulting firms.

Per-scan pricing was appealing to bug bounty hunters and light users who do not have consistent testing volume. The price sensitivity for this group was high -- most cited \$20 to \$60 per scan as the acceptable range. Anything above \$100 per scan was rejected as unworkable for bug bounty economics.

Regional Pricing Note

Respondents from Latin America, Africa, and Southeast Asia consistently identified US-market SaaS pricing as prohibitive. Ten respondents from these regions indicated that regional pricing at 40 to 60 percent of US pricing would be necessary for adoption. This represents an underserved market with lower per-engagement revenue but potentially high volume.

7. FEATURE PRIORITY RANKING

Based on analysis of responses across all 100 interviews, the following features were identified as highest priority, ranked by frequency of mention and intensity of expressed need:

Priority	Feature	Mentioned By
1	Strict scope enforcement with hard boundaries	97 respondents
2	Accurate findings with low false positive rate	91 respondents

4	Report generation in client-ready format	83 respondents
5	Compliance framework mapping (PCI, HIPAA, NIST, etc.)	71 respondents
6	Attack surface management / asset discovery	68 respondents
7	AD attack path analysis (BloodHound-level)	61 respondents
8	Autonomous recon phase, human-controlled exploit	58 respondents
9	Cloud environment testing (AWS, Azure, GCP)	54 respondents
10	Executive summary auto-generation	49 respondents
11	API and GraphQL testing	38 respondents
12	Custom template / module upload	31 respondents
13	Continuous monitoring mode	28 respondents
14	Post-pentest cleanup automation	22 respondents

8. SEGMENT-SPECIFIC FINDINGS

Red Team Operators (35 respondents)

Red teamers were the most nuanced in their requirements. They were generally positive about autonomous recon but resistant to autonomous exploitation. The primary concern was OPSEC -- the noise profile of an automated tool would compromise covert engagements. Several respondents identified a specific use case: running autonomous recon and scanning in parallel while the human operator focuses on initial access. This 'parallel operator' framing was compelling to many in this segment.

Red teamers in financial services and critical infrastructure had significantly higher requirements around audit trails and regulatory documentation. For this sub-segment, the platform's ability to produce regulator-ready documentation was as important as its technical capability.

Penetration Testers (28 respondents)

Penetration testers were the segment most receptive to autonomous assistance across the full engagement cycle. They expressed strong interest in a tool that could handle recon, initial scanning, and first-pass triage, freeing them to focus on manual exploitation and post-exploitation. Report writing automation was the single most mentioned feature request in this segment.

Specialty testers (web app, cloud, mobile, OT) identified significant gaps in the current capability of AI pentest platforms for their specific domains. Authorization testing (IDOR, BFLA) and API security were most frequently cited as underserved areas.

Bug Bounty Hunters (15 respondents)

Bug bounty respondents were the most price-sensitive segment and had the most specific requirements around program compliance -- tools that generate noisy traffic can get researchers banned from programs. Several respondents asked explicitly about rate limiting and traffic profile controls.

The key insight from this segment: they do not need the tool to find the same bugs everyone else finds. Mature programs have already seen the commodity findings. The value would come from finding novel bugs that manual testing and standard automation miss. That is a harder problem but it is the real ask.

Freelancers and Independent Consultants (12 respondents)

Freelancers were most focused on economics -- the tool needs to reduce time per engagement enough to either increase margin or increase volume. The break-even calculation was similar across this group: at \$500 per month, the tool needs to save at least three to four hours per engagement across a typical monthly volume of five to eight engagements.

A pause or suspend option was universally important in this segment due to gaps between projects. Annual contracts were rejected by all freelance respondents.

Enterprise Corporate Red Teams (10 respondents)

Enterprise respondents had the highest budget tolerance but also the highest barrier to adoption. Procurement, legal review, security assessment of the platform itself, and regulatory compliance were all mentioned as prerequisites that typically take six to twelve months. Enterprise respondents recommended investing in SOC 2, ISO 27001, and sector-specific certifications

Annual licensing and enterprise-wide agreements were the expected commercial model. Per-seat or per-scan pricing was not workable for enterprise procurement. Dedicated customer success and SLA-backed support were expected at enterprise pricing levels.

9. NOTABLE QUOTES

"I can finish an engagement in two days and spend three days writing it up. The evidence gathering, the narrative, correlating findings -- it is the worst part of this job and nobody talks about it."

-- Marcus Webb, Senior Red Team Lead

"The moment it does something I did not anticipate and cannot trace back to a decision node, I am done with it. Scope enforcement is non-negotiable."

-- Lena Brandt, Principal Penetration Tester

"Show me the kill switch first. I need to be able to stop it instantly with a single action and know that it actually stops."

-- Terrence Booker, Offensive Security Engineer

"If it can do threat actor-specific simulation -- constrain itself to our threat actor's known TTPs -- that would make it relevant to our work rather than just running a generic attack."

-- Maria Santos, Lead Red Team Engineer

"I would use it as a learning tool -- see what it finds and then understand why it found it. That is probably not the primary use case you are selling but it is real."

-- Brendan Walsh, Red Team Analyst

"Real environments are messy and that tool clearly trained on CTF scenarios."

-- Derek Holloway, Offensive Security Engineer

"The commodity pentest automation case is genuinely compelling as a business model. I can sell commodity engagements with the AI doing the work and review and sign off."

-- Eli Rosen, Red Team Operator

"If it produced DORA-compliant documentation automatically, that would be immediately valuable. That is a concrete compliance need right now."

-- Hugo Delacroix, Independent Penetration Tester

"I would use it to justify expanding our coverage without hiring another headcount. That is the business case I can sell to my CISO."

-- Blake Turner, Red Team Lead

"Twenty years of reputation is on the line with every engagement. If the output quality is something I can stand behind with a client, it earns a place."

-- Roland Steele, Independent Security Consultant

"Critical infrastructure has specific requirements -- the tool would need to demonstrate that it cannot be weaponized against critical infrastructure."

-- Adam Blackwood, Enterprise Red Team Lead

"If it operates stealthily I would be very interested. Show me the OPSEC design before anything else."

-- Victor Huang, Principal Red Team Engineer

10. RECOMMENDATIONS FOR CHELYS

Lead with scope enforcement in every conversation

This was the single most frequently cited requirement and the only one where failure means immediate disqualification. Demonstrate it concretely and early in every sales conversation. Show the hard boundaries, show what happens when a target is added, show the scope violation detection. Make it a feature tour, not a checkbox.

Position the recon and triage phases as the initial value proposition

Across segments, the most acceptable form of autonomy was handling reconnaissance, asset discovery, and initial vulnerability triage. Autonomous exploitation is aspirational for most respondents. The near-term commercial value is in compressing the mechanical early phases of every engagement.

Build compliance mapping as a first-class feature for regulated markets

Healthcare (HIPAA), financial services (PCI, DORA, FFIEC, SAMA), and government (NIST, FedRAMP) respondents expressed disproportionately high willingness to pay for compliance-aware reporting. This is an underserved feature in existing tools and a potential price premium driver.

Invest in the report generation experience

91 percent of respondents cited report writing as a major pain point. A tool that produces client-ready findings with executive summaries, accurate severity, evidence-backed findings, and compliance mappings -- without manual editing -- would be cited as transformative by the majority of respondents. This is likely the single highest-leverage product investment.

Offer a meaningful pause or suspend option in monthly plans

34 respondents mentioned this explicitly. For independent consultants and freelancers, the ability to suspend a subscription during slow periods is a meaningful decision factor. At the same price point, a plan with a pause option wins over one without.

Enterprise sales requires certification investment before outreach

Enterprise respondents consistently flagged SOC 2 Type II, ISO 27001, and sector-specific certifications as prerequisites for procurement consideration. Starting the enterprise sales motion before these certifications are complete wastes cycles.

Consider per-scan pricing as a lower-barrier entry point for bug bounty

The bug bounty segment is price-sensitive but has high volume potential. A per-scan entry point at \$25 to \$60 per target could build a customer base that converts to monthly subscriptions as usage grows. This segment also generates public-facing credibility if the tool helps find real bugs.

Regional pricing is required to access non-US markets

Ten respondents from emerging markets indicated that standard US SaaS pricing was prohibitive. A regional pricing tier at 40 to 60 percent of US pricing could open Latin American, African, and Southeast Asian markets that are currently inaccessible.

Next: Begin product validation with the 12 respondents who requested a trial or beta access.